AI-Powered Patch & Vulnerability Report

Generated by Patch/Vulnerability Report Builder

1. Executive Summary

CYBERSECURITY VULNERABILITY & PATCH REPORT (STATIC FALLBACK)

EXECUTIVE SUMMARY

This report provides a high-level summary of the vulnerability scan data. A total of **20** vulnerabilities were analyzed, ranging from Low to Critical risk profiles.

RISK DISTRIBUTION
- **Critical (CVSS >= 9.0)**: 11
- **High (7.0 <= CVSS < 9.0)**: 9
- **Medium (4.0 <= CVSS < 7.0)**: 0
- **Low (CVSS < 4.0)**: 0

HIGH-LEVEL CYBER POSTURE REVIEW
The scan indicates active exposures across several systems. Immediate remediation focus should be dedicated to resolving Critical and High severity findings, which represent the path of least resistance for potential threat actors.

KEY STRATEGIC RECOMMENDATIONS

1. **Immediate Remediation Campaign**: Prioritize patching of the top risk vectors listed below.
2. **Implement Compensating Controls**: Where patching is delayed due to system dependency constraints, restrict network access.
3. **Enhance Patch Cycle SLAs**: Establish a vulnerability management policy with strict SLAs (e.g., 48 hours for Criticals).

TOP RISKS UNDER ANALYSIS
- **CVE-2024-3400** (CVSS: 10.0 - Critical): A command injection as a result of arbitrary file creation vulnerability in the GlobalProtect feature of Palo Alto Netwo...
- **CVE-2024-3094** (CVSS: 10.0 - Critical): Malicious code was discovered in the upstream tarballs of xz, starting with version 5.6.0.
Through a series of complex...
- **CVE-2024-1709** (CVSS: 10.0 - Critical): ConnectWise ScreenConnect 23.9.7 and prior are affected by an Authentication Bypass Using an Alternate Path or Channel

...
- **CVE-2024-4577** (CVSS: 9.8 - Critical): In PHP versions 8.1.* before 8.1.29, 8.2.* before 8.2.20, 8.3.* before 8.3.8, when using Apache and PHP-CGI on Windows, ...

- **CVE-2024-27198** (CVSS: 9.8 - Critical): In JetBrains TeamCity before 2023.11.4 authentication bypass allowing to perform admin actions was possible...

2. Severity Statistics & Key Metrics

Total Vulnerabilities: 20	Critical (CVSS >= 9.0): 11
High (CVSS >= 7.0): 9	Medium (CVSS >= 4.0): 0
Low (CVSS < 4.0): 0	

3. Top Risk Registry

Rank	CVE ID	CVSS Score	Severity	Published Date
1	CVE-2024-3400	10.0	Critical	2024-04-12
2	CVE-2024-3094	10.0	Critical	2024-03-29
3	CVE-2024-1709	10.0	Critical	2024-02-21
4	CVE-2024-4577	9.8	Critical	2024-06-09
5	CVE-2024-27198	9.8	Critical	2024-03-04
6	CVE-2024-23897	9.8	Critical	2024-01-24
7	CVE-2024-21762	9.8	Critical	2024-02-09
8	CVE-2024-21413	9.8	Critical	2024-02-13
9	CVE-2023-3519	9.8	Critical	2023-07-19
10	CVE-2024-21887	9.1	Critical	2024-01-12
11	CVE-2024-32002	9.0	Critical	2024-05-14
12	CVE-2024-23222	8.8	High	2024-01-23
13	CVE-2024-20674	8.8	High	2024-01-09
14	CVE-2023-4863	8.8	High	2023-09-12
15	CVE-2024-24919	8.6	High	2024-05-28
16	CVE-2024-6387	8.1	High	2024-07-01
17	CVE-2024-1086	7.8	High	2024-01-31
18	CVE-2023-44487	7.5	High	2023-10-10
19	CVE-2024-3273	7.3	High	2024-04-04
20	CVE-2024-2961	7.3	High	2024-04-17

1. CVE-2024-3400

CVSS Score: 10.0 **Severity: Critical** **Published: 2024-04-12**

NVD Description

A command injection as a result of arbitrary file creation vulnerability in the GlobalProtect feature of Palo Alto Networks PAN-OS software for specific PAN-OS versions and distinct feature configurations may enable an unauthenticated attacker to execute arbitrary code with root privileges on the firewall.

Cloud NGFW, Panorama appliances, and Prisma Access are not impacted by this vulnerability.

Business Impact

Exploitation of CVE-2024-3400 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: A command injection as a result of arbitrary file creation vulnerability in the GlobalProtect feature of Palo Alto Networks PAN-OS software for specif...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 10.0). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://security.paloaltonetworks.com/CVE-2024-3400
- https://unit42.paloaltonetworks.com/cve-2024-3400/
- https://www.paloaltonetworks.com/blog/2024/04/more-on-the-pan-os-cve/

2. CVE-2024-3094

CVSS Score: 10.0 **Severity: Critical** **Published: 2024-03-29**

NVD Description

Malicious code was discovered in the upstream tarballs of xz, starting with version 5.6.0.
Through a series of complex obfuscations, the liblzma build process extracts a prebuilt object file from a disguised test file existing in the source code, which is then used to modify specific functions in the liblzma code. This results in a modified liblzma library that can be used by any software linked against this library, intercepting and modifying the data interaction with this library.

Business Impact

Exploitation of CVE-2024-3094 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: Malicious code was discovered in the upstream tarballs of xz, starting with version 5.6.0.
Through a series of complex obfuscations, the liblzma bui...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 10.0). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://access.redhat.com/security/cve/CVE-2024-3094
- https://bugzilla.redhat.com/show_bug.cgi?id=2272210
- https://www.openwall.com/lists/oss-security/2024/03/29/4

3. CVE-2024-1709

CVSS Score: 10.0 **Severity: Critical** **Published: 2024-02-21**

NVD Description

ConnectWise ScreenConnect 23.9.7 and prior are affected by an Authentication Bypass Using an Alternate Path or Channel

vulnerability, which may allow an attacker direct access to confidential information or

critical systems.

Business Impact

Exploitation of CVE-2024-1709 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: ConnectWise ScreenConnect 23.9.7 and prior are affected by an Authentication Bypass Using an Alternate Path or Channel

vulnerability, which may allo...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 10.0). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://github.com/rapid7/metasploit-framework/pull/18870
- https://github.com/watchtowrlabs/connectwise-screenconnect_auth-bypass-add-user-poc
- https://techcrunch.com/2024/02/21/researchers-warn-high-risk-connectwise-flaw-under-attack-is-embarrassingly-easy-to-exploit/

4. CVE-2024-4577

CVSS Score: 9.8 **Severity: Critical** **Published: 2024-06-09**

NVD Description

In PHP versions 8.1.* before 8.1.29, 8.2.* before 8.2.20, 8.3.* before 8.3.8, when using Apache and PHP-CGI on Windows, if the system is set up to use certain code pages, Windows may use "Best-Fit" behavior to replace characters in command line given to Win32 API functions. PHP CGI module may misinterpret those characters as PHP options, which may allow a malicious user to pass options to PHP binary being run, and thus reveal the source code of scripts, run arbitrary PHP code on the server, etc.

Business Impact

Exploitation of CVE-2024-4577 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: In PHP versions 8.1.* before 8.1.29, 8.2.* before 8.2.20, 8.3.* before 8.3.8, when using Apache and PHP-CGI on Windows, if the system is set up to use...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 9.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://www.openwall.com/lists/oss-security/2024/06/07/1
- https://arstechnica.com/security/2024/06/php-vulnerability-allows-attackers-to-run-malicious-code-on-windows-servers/
- https://blog.orange.tw/2024/06/cve-2024-4577-yet-another-php-rce.html

5. CVE-2024-27198

CVSS Score: 9.8 **Severity: Critical** **Published: 2024-03-04**

NVD Description

In JetBrains TeamCity before 2023.11.4 authentication bypass allowing to perform admin actions was possible

Business Impact

Exploitation of CVE-2024-27198 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: In JetBrains TeamCity before 2023.11.4 authentication bypass allowing to perform admin actions was possible...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 9.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://www.darkreading.com/cyberattacks-data-breaches/jetbrains-teamcity-mass-exploitation-underway-rogue-accounts-thrive
- https://www.jetbrains.com/privacy-security/issues-fixed/
- https://www.darkreading.com/cyberattacks-data-breaches/jetbrains-teamcity-mass-exploitation-underway-rogue-accounts-thrive

6. CVE-2024-23897

CVSS Score: 9.8 **Severity: Critical** **Published: 2024-01-24**

NVD Description

Jenkins 2.441 and earlier, LTS 2.426.2 and earlier does not disable a feature of its CLI command parser that replaces an '@' character followed by a file path in an argument with the file's contents, allowing unauthenticated attackers to read arbitrary files on the Jenkins controller file system.

Business Impact

Exploitation of CVE-2024-23897 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: Jenkins 2.441 and earlier, LTS 2.426.2 and earlier does not disable a feature of its CLI command parser that replaces an '@' character followed by a f...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 9.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://packetstormsecurity.com/files/176839/Jenkins-2.441-LTS-2.426.3-CVE-2024-23897-Scanner.html
- http://packetstormsecurity.com/files/176840/Jenkins-2.441-LTS-2.426.3-Arbitrary-File-Read.html
- http://www.openwall.com/lists/oss-security/2024/01/24/6

7. CVE-2024-21762

CVSS Score: 9.8 **Severity: Critical** **Published: 2024-02-09**

NVD Description

A out-of-bounds write in Fortinet FortiOS versions 7.4.0 through 7.4.2, 7.2.0 through 7.2.6, 7.0.0 through 7.0.13, 6.4.0 through 6.4.14, 6.2.0 through 6.2.15, 6.0.0 through 6.0.17, FortiProxy versions 7.4.0 through 7.4.2, 7.2.0 through 7.2.8, 7.0.0 through 7.0.14, 2.0.0 through 2.0.13, 1.2.0 through 1.2.13, 1.1.0 through 1.1.6, 1.0.0 through 1.0.7 allows attacker to execute unauthorized code or commands via specifically crafted requests

Business Impact

Exploitation of CVE-2024-21762 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: A out-of-bounds write in Fortinet FortiOS versions 7.4.0 through 7.4.2, 7.2.0 through 7.2.6, 7.0.0 through 7.0.13, 6.4.0 through 6.4.14, 6.2.0 through...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 9.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://fortiguard.com/psirt/FG-IR-24-015
- https://fortiguard.com/psirt/FG-IR-24-015
- https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2024-21762

8. CVE-2024-21413

CVSS Score: 9.8 **Severity: Critical** **Published: 2024-02-13**

NVD Description

Microsoft Outlook Remote Code Execution Vulnerability

Business Impact

Exploitation of CVE-2024-21413 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: Microsoft Outlook Remote Code Execution Vulnerability...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 9.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-21413
- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-21413
- https://research.checkpoint.com/2024/the-risks-of-the-monikerlink-bug-in-microsoft-outlook-and-the-big-picture/

9. CVE-2023-3519

CVSS Score: 9.8 **Severity: Critical** **Published: 2023-07-19**

NVD Description

Unauthenticated remote code execution

Business Impact

Exploitation of CVE-2023-3519 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: Unauthenticated remote code execution...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 9.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://packetstormsecurity.com/files/173997/Citrix-ADC-NetScaler-Remote-Code-Execution.html
- https://support.citrix.com/article/CTX561482/citrix-adc-and-citrix-gateway-security-bulletin-for-cve20233519-cve20233466-cve20233467
- http://packetstormsecurity.com/files/173997/Citrix-ADC-NetScaler-Remote-Code-Execution.html

10. CVE-2024-21887

CVSS Score: 9.1 **Severity: Critical** **Published: 2024-01-12**

NVD Description

A command injection vulnerability in web components of Ivanti Connect Secure (9.x, 22.x) and Ivanti Policy Secure (9.x, 22.x) allows an authenticated administrator to send specially crafted requests and execute arbitrary commands on the appliance.

Business Impact

Exploitation of CVE-2024-21887 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: A command injection vulnerability in web components of Ivanti Connect Secure (9.x, 22.x) and Ivanti Policy Secure (9.x, 22.x) allows an authenticated...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 9.1). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://packetstormsecurity.com/files/176668/Ivanti-Connect-Secure-Unauthenticated-Remote-Code-Execution.html
- https://forums.ivanti.com/s/article/CVE-2023-46805-Authentication-Bypass-CVE-2024-21887-Command-Injection-for-Ivanti-Connect-Secure-and-Ivan
- http://packetstormsecurity.com/files/176668/Ivanti-Connect-Secure-Unauthenticated-Remote-Code-Execution.html

11. CVE-2024-32002

CVSS Score: 9.0 **Severity: Critical** **Published: 2024-05-14**

NVD Description

Git is a revision control system. Prior to versions 2.45.1, 2.44.1, 2.43.4, 2.42.2, 2.41.1, 2.40.2, and 2.39.4, repositories with submodules can be crafted in a way that exploits a bug in Git whereby it can be fooled into writing files not into the submodule's worktree but into a `.git/` directory. This allows writing a hook that will be executed while the clone operation is still running, giving the user no opportunity to inspect the code that is being executed. The problem has been patched in versions 2.45.1, 2.44.1, 2.43.4, 2.42.2, 2.41.1, 2.40.2, and 2.39.4. If symbolic link support is disabled in Git (e.g. via `git config --global core.symlinks false`), the described attack won't work. As always, it is best to avoid cloning repositories from untrusted sources.

Business Impact

Exploitation of CVE-2024-32002 could lead to operational disruption. Given the Critical severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: Git is a revision control system. Prior to versions 2.45.1, 2.44.1, 2.43.4, 2.42.2, 2.41.1, 2.40.2, and 2.39.4, repositories with submodules can be cr...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as Critical (CVSS: 9.0). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://www.openwall.com/lists/oss-security/2024/05/14/2
- https://git-scm.com/docs/git-clone#Documentation/git-clone.txt---recurse-submodulesltpathspecgt
- https://git-scm.com/docs/git-config#Documentation/git-config.txt-coresymlinks

12. CVE-2024-23222

CVSS Score: 8.8 **Severity: High** **Published: 2024-01-23**

NVD Description

A type confusion issue was addressed with improved checks. This issue is fixed in Safari 17.3, iOS 15.8.7 and iPadOS 15.8.7, iOS 16.7.5 and iPadOS 16.7.5, iOS 17.3 and iPadOS 17.3, macOS Monterey 12.7.3, macOS Sonoma 14.3, macOS Ventura 13.6.4, tvOS 17.3, visionOS 1.0.2. Processing maliciously crafted web content may lead to arbitrary code execution. This fix associated with the Coruna exploit was shipped in iOS 17.3 on January 22, 2024. This update brings that fix to devices that cannot update to the latest iOS version.

Business Impact

Exploitation of CVE-2024-23222 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: A type confusion issue was addressed with improved checks. This issue is fixed in Safari 17.3, iOS 15.8.7 and iPadOS 15.8.7, iOS 16.7.5 and iPadOS 16....)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 8.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://support.apple.com/en-us/118479
- https://support.apple.com/en-us/120304
- https://support.apple.com/en-us/120305

13. CVE-2024-20674

CVSS Score: 8.8 **Severity: High** **Published: 2024-01-09**

NVD Description

Windows Kerberos Security Feature Bypass Vulnerability

Business Impact

Exploitation of CVE-2024-20674 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: Windows Kerberos Security Feature Bypass Vulnerability...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 8.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-20674
- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-20674

14. CVE-2023-4863

CVSS Score: 8.8 **Severity: High** **Published: 2023-09-12**

NVD Description

Heap buffer overflow in libwebp in Google Chrome prior to 116.0.5845.187 and libwebp 1.3.2 allowed a remote attacker to perform an out of bounds memory write via a crafted HTML page. (Chromium security severity: Critical)

Business Impact

Exploitation of CVE-2023-4863 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: Heap buffer overflow in libwebp in Google Chrome prior to 116.0.5845.187 and libwebp 1.3.2 allowed a remote attacker to perform an out of bounds memor...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 8.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://www.openwall.com/lists/oss-security/2023/09/21/4
- http://www.openwall.com/lists/oss-security/2023/09/22/1
- http://www.openwall.com/lists/oss-security/2023/09/22/3

15. CVE-2024-24919

CVSS Score: 8.6 **Severity: High** **Published: 2024-05-28**

NVD Description

Potentially allowing an attacker to read certain information on Check Point Security Gateways once connected to the internet and enabled with remote Access VPN or Mobile Access Software Blades. A Security fix that mitigates this vulnerability is available.

Business Impact

Exploitation of CVE-2024-24919 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: Potentially allowing an attacker to read certain information on Check Point Security Gateways once connected to the internet and enabled with remote A...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 8.6). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://support.checkpoint.com/results/sk/sk182336
- https://support.checkpoint.com/results/sk/sk182336
- https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2024-24919

16. CVE-2024-6387

CVSS Score: 8.1 **Severity: High** **Published: 2024-07-01**

NVD Description

A security regression (CVE-2006-5051) was discovered in OpenSSH's server (sshd). There is a race condition which can lead sshd to handle some signals in an unsafe manner. An unauthenticated, remote attacker may be able to trigger it by failing to authenticate within a set time period.

Business Impact

Exploitation of CVE-2024-6387 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: A security regression (CVE-2006-5051) was discovered in OpenSSH's server (sshd). There is a race condition which can lead sshd to handle some signals ...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 8.1). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://access.redhat.com/errata/RHSA-2024:4312
- https://access.redhat.com/errata/RHSA-2024:4340
- https://access.redhat.com/errata/RHSA-2024:4389

17. CVE-2024-1086

CVSS Score: 7.8 **Severity: High** **Published: 2024-01-31**

NVD Description

A use-after-free vulnerability in the Linux kernel's netfilter: nf_tables component can be exploited to achieve local privilege escalation.

The nft_verdict_init() function allows positive values as drop error within the hook verdict, and hence the nf_hook_slow() function can cause a double free vulnerability when NF_DROP is issued with a drop error which resembles NF_ACCEPT.

We recommend upgrading past commit f342de4e2f33e0e39165d8639387aa6c19dff660.

Business Impact

Exploitation of CVE-2024-1086 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: A use-after-free vulnerability in the Linux kernel's netfilter: nf_tables component can be exploited to achieve local privilege escalation.

The nft_v...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 7.8). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://www.openwall.com/lists/oss-security/2024/04/10/22
- http://www.openwall.com/lists/oss-security/2024/04/10/23
- http://www.openwall.com/lists/oss-security/2024/04/14/1

18. CVE-2023-44487

CVSS Score: 7.5 **Severity: High** **Published: 2023-10-10**

NVD Description

The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.

Business Impact

Exploitation of CVE-2023-44487 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 7.5). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://www.openwall.com/lists/oss-security/2023/10/10/6
- http://www.openwall.com/lists/oss-security/2023/10/10/7
- http://www.openwall.com/lists/oss-security/2023/10/13/4

19. CVE-2024-3273

CVSS Score: 7.3 **Severity: High** **Published: 2024-04-04**

NVD Description

** UNSUPPORTED WHEN ASSIGNED ** A vulnerability, which was classified as critical, was found in D-Link DNS-320L, DNS-325, DNS-327L and DNS-340L up to 20240403. Affected is an unknown function of the file /cgi-bin/nas_sharing.cgi of the component HTTP GET Request Handler. The manipulation of the argument system leads to command injection. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used. The identifier of this vulnerability is VDB-259284. NOTE: This vulnerability only affects products that are no longer supported by the maintainer. NOTE: Vendor was contacted early and confirmed immediately that the product is end-of-life. It should be retired and replaced.

Business Impact

Exploitation of CVE-2024-3273 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: ** UNSUPPORTED WHEN ASSIGNED ** A vulnerability, which was classified as critical, was found in D-Link DNS-320L, DNS-325, DNS-327L and DNS-340L up to ...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 7.3). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- https://github.com/netsecfish/dlink
- https://supportannouncement.us.dlink.com/security/publication.aspx?name=SAP10383
- https://vuldb.com/?ctiid.259284

20. CVE-2024-2961

CVSS Score: 7.3 **Severity: High** **Published: 2024-04-17**

NVD Description

The iconv() function in the GNU C Library versions 2.39 and older may overflow the output buffer passed to it by up to 4 bytes when converting strings to the ISO-2022-CN-EXT character set, which may be used to crash an application or overwrite a neighbouring variable.

Business Impact

Exploitation of CVE-2024-2961 could lead to operational disruption. Given the High severity, this poses a notable threat to business continuity, potentially exposing sensitive data or creating entry points for ransomware.

Executive Explanation

A vulnerability exists that affects systems. An attacker could exploit this to bypass security measures or execute unauthorized actions. (Original Description: The iconv() function in the GNU C Library versions 2.39 and older may overflow the output buffer passed to it by up to 4 bytes when converting strings...)

Recommended Remediation

Apply vendor-released security patches immediately. If patches are not feasible, implement firewall ingress rules to restrict network access, and enable logging to detect exploit attempts.

Priority Justification

Classified as High (CVSS: 7.3). This should be prioritized for remediation in line with standard SLA guidelines (e.g., within 14 days for high risk, 30 days for medium).

References

- http://www.openwall.com/lists/oss-security/2024/04/17/9
- http://www.openwall.com/lists/oss-security/2024/04/18/4
- http://www.openwall.com/lists/oss-security/2024/04/24/2